UNIT IV
ACCESS CONTROL

Access control principles are fundamental concepts used to define how users and systems can interact with resources in a secure environment. These principles ensure that sensitive data and systems are only accessed by authorized individuals or systems. The main access control principles include:

1. Least Privilege: Users and systems should only have the minimum level of access (privileges) required to perform their duties. This minimizes the risk of unauthorized access or actions, reducing the potential damage if an account is compromised.

Example: A user who needs to read data should not be given permission to modify or delete that data.

2. Need to Know: Access to resources should be granted only if it is necessary for the specific task or role. Restricting access to only the information needed for a job role helps limit exposure of sensitive data.

Example: An accountant should have access only to financial records, not to HR files or system configuration data.

3. Separation of Duties: No single user should have enough access to misuse a system on their own. Critical tasks should be divided between multiple users to reduce the risk of fraud or errors. It helps prevent a single user from carrying out malicious activities, such as modifying critical records or accessing restricted resources.

- **Example**: In a financial system, one person may approve transactions, while another person processes them.

4. Accountability: Every action taken on a system should be logged and traceable to an individual or system. This ensures that users can be held accountable for their actions. It allows the organization to audit and review user activities, detect potential malicious actions, and maintain compliance.

- **Example**: If a file is accessed, the system logs which user accessed it, when, and what they did with the file.

5. Authorization: Authorization is the process of determining what actions a user or system is allowed to perform on resources after their identity is authenticated. It ensures that a user is granted only the specific access they are authorized for based on their role or other factors.

- **Example**: A user may be authorized to view a report but not edit or delete it.

6. Authentication: Authentication is the process of verifying the identity of a user or system before allowing access to resources. It ensures that only legitimate users or systems are granted access.

- **Example**: A user might authenticate via a username and password, multi-factor authentication (MFA), or biometric methods.

7. Authorization Models

- These models help define how access control decisions are made:
  - **Discretionary Access Control (DAC)**: The owner of a resource determines who has access to it.
  - **Mandatory Access Control (MAC)**: Access is determined by the system based on predefined policies, and users cannot change the access settings.

8. Time-based Access Control: Limiting access to certain resources based on the time of day or specific dates. It helps restrict access to systems when it's not necessary (e.g., outside business hours) or for specific time-sensitive tasks.

These principles together form the foundation of effective access control systems, aiming to secure sensitive data and minimize the risks of unauthorized access or malicious activity.

Access Control Context

In the context of access control, **context** refers to the specific circumstances, conditions, and factors that influence how access to resources and systems is granted or denied. Access control context helps to define when, where, and how access should be granted, and may involve additional factors beyond just user identity and roles. Understanding access control in context is important for implementing flexible and dynamic security models, and it includes:

1. User Context:

User identity: The specific identity of the individual trying to access a resource, often verified through authentication mechanisms (username, password, biometrics, etc.).

Roles and responsibilities: Users may have different levels of access depending on their role in the organization (e.g., administrator, manager, employee and contractor).

Attributes: Access might be based on user-specific attributes, such as department, group membership, clearance level, etc.

2. Resource Context

- **Type of resource**: The nature of the resource being accessed (e.g., files, applications, servers, databases). Different resources may require different levels of protection based on their sensitivity.
- **Data sensitivity**: Resources like sensitive financial data, personal information, or intellectual property may require stricter access controls compared to general information.
- **Resource location**: The physical or logical location of the resource can influence access decisions. For instance, access to a resource may depend on whether it's on a local network or accessed remotely.

3. Environmental Context

- **Time and date**: Access may be granted or denied based on time-related factors, such as business hours or specific operational windows.
- **Geographical location**: Access could be restricted based on the user's geographical location. For example, an employee working remotely from an unauthorized country might be denied access.
- **Device context**: The device used to access a resource (e.g., personal laptop, company-issued device, mobile phone) can influence access decisions, based on security policies like device health checks or whether the device is registered within the organization.
- **Network conditions**: Access could be influenced by the security of the network being used. For instance, access might be granted only if the user is on a trusted VPN or corporate network, and denied over insecure public Wi-Fi.

4. Behavioral Context

- **User behavior patterns**: Anomalies in a user's behavior, such as accessing resources they don't normally use, can trigger additional security checks. For example, if a user accesses critical data they've never interacted with before, it could be flagged for review.
- **Risk assessment**: Continuous monitoring of user activity can help assess risk, adjusting the level of scrutiny or access control dynamically. If a user's behavior becomes suspicious, their access may be reduced or temporarily revoked.

5. Contextual Security Policies

- **Risk-based access control**: Access decisions are made based on a risk assessment of the context. For example, high-risk activities (e.g., transferring large sums of money) may require stronger authentication or a manager's approval.
- **Adaptive authentication**: The system may adjust the level of authentication required depending on contextual factors. For example, a user may be prompted for multi-factor authentication (MFA) if they are accessing a resource from an unknown device or location.
- **Dynamic policy enforcement**: Policies can be dynamic, meaning they adapt based on changing contexts like a user's location, time of access, or device security status. This allows access control systems to respond in real-time to emerging threats.

6. Contextual Access Control Models: Contextual factors can be used to implement advanced access control models:

- **Attribute-Based Access Control (ABAC)**: ABAC allows for fine-grained access control by combining attributes of users, resources, actions, and environment. For example, a user may be granted access to a document only if they belong to a specific department, are accessing it within business hours, and are using a company-issued device.
- **Risk-Adaptive Access Control**: This approach uses a dynamic, risk-based model to adjust access levels based on context and risk assessments. It is used in environments where access decisions must change quickly to respond to evolving threats or user behavior.

Examples of Contextual Access Control:

- **Time-based restrictions**: A user may have access to a resource only between 9:00 AM and 5:00 PM on weekdays, but not during nights or weekends.
- **Geographic restrictions**: A user might be restricted from accessing a corporate system if they are located in a country where the organization doesn't operate, or if they attempt to access the system from a suspicious IP address.
- **Device security status**: A user may be allowed to access a resource only from a device that has up-to-date antivirus software or meets other security requirements.

Benefits of Contextual Access Control:

- **Increased Security**: Access control policies are more dynamic and adaptive to changing circumstances, which reduces the risk of unauthorized access or data breaches.
- **Better User Experience**: By applying appropriate levels of access based on context, users can have more seamless access when appropriate (e.g., remote access from a trusted device) while still protecting critical resources.
- **Granular Control**: Organizations can implement highly granular and sophisticated access control policies, based on multiple contextual factors, to enhance overall security posture.

In summary, access control context considers a broad range of factors—ranging from user identity to environmental conditions—to make smarter, more flexible decisions about who can access what resources, when, and under what conditions. This approach enhances security by ensuring access is granted only when it's safe to do so.

Access Control policies

Access control policies define the rules and guidelines for who can access what resources, under what conditions, and with what level of privileges. These policies ensure that only authorized users and systems can access sensitive information or resources, and they help enforce the principle of least privilege, accountability, and compliance. Below are key types of **access control policies** commonly implemented are as follows.

1. Discretionary Access Control (DAC) Policy: In DAC, the resource owner (typically a user) determines who has access to their resources. The owner can grant or revoke permissions to other users or groups.

- **Policy Features**:
  - **User-driven access**: The resource owner has control over access decisions.
  - **Permissions inheritance**: Users can inherit permissions from the owner or parent directories.
  - **Flexible but less secure**: While flexible, DAC can be risky, as owners might not always make secure choices for granting access.

2. Mandatory Access Control (MAC) Policy: In MAC, access decisions are made by the system based on predefined security policies, and users cannot change or override these policies. MAC typically uses labels to categorize resources and users, and access is based on these labels.

- **Policy Features**:
    - **System-enforced access rules**: Access control is centrally managed and strictly enforced, reducing human error or malicious activity.
    - **Security labels**: Users and resources are assigned labels (e.g., "Confidential," "Top Secret"), and access is determined based on these labels and predefined policies.
    - **No user discretion**: Users cannot modify or bypass access control settings.

3. Role-Based Access Control (RBAC) Policy: In RBAC, users are assigned roles within an organization, and access to resources is based on these roles. Roles are linked to permissions, and users inherit the permissions assigned to their role.

- **Policy Features**:
    - **Role assignments**: Users are granted access based on their organizational role (e.g., administrator, manager, employee).
    - **Role hierarchies**: Roles can have hierarchies, where higher roles inherit permissions from lower ones (e.g., managers might inherit permissions of regular employees).
    - **Separation of duties**: Ensures that critical functions (e.g., approval of transactions) are divided among different roles to prevent fraud.

4. Attribute-Based Access Control Policy: This policies control access based on attributes (properties) of users, resources, and the environment. These attributes could include a user's role, department, location, time of access, or the classification of the data.

5. Rule-Based Access Control Policy: Rule-based access control policies enforce access based on predefined rules rather than roles or attributes. Rules may take the form of conditions, such as "if a user is on a particular network, they can access the resource."

6. Time-Based Access Control Policy: Time-based access control restricts access to resources based on the time of day or specific time periods.

7. Context-Based Access Control Policy: Context-based access control policies evaluate the context surrounding a user's request to determine whether they should be granted access. Context may include location, device security, or network status.

8. Multi-Factor Authentication (MFA) Policy: An access control policy that requires users to provide more than one form of authentication before being granted access.

9. Least Privilege Access Control Policy: The principle that users should be given the least amount of access necessary to perform their tasks, reducing the risk of unauthorized access or misuse.

10. Separation of Duties (SoD) Policy: Separation of duties ensures that no single individual has ability the to perform critical tasks on their own that could lead to fraud or mistakes. The responsibilities for sensitive operations (e.g., approving and processing transactions) are divided across multiple individuals.

Access control policies are vital for securing resources and ensuring that only authorized users can access sensitive data or systems. The choice of which policy to implement depends on factors like the organization's security needs, user roles, the sensitivity of resources, and regulatory requirements. Access control policies can range from simple models like DAC to more complex ones like ABAC, providing different levels of flexibility and security for organizations.

Subject, Object & Access rights:

In access control, the terms **subject**, **object**, and **access rights** are fundamental concepts that define how access is granted, managed, and enforced. Understanding these terms is crucial for designing effective access control systems.

1. Subject: A subject refers to an entity that **requests access** to a resource or performs actions on an object. Typically, a subject is a user, process, or system that interacts with a system or application.

- **Example**: In most systems, the subject would be a **user** (e.g., an employee accessing a file), a **program** (e.g., a software application performing tasks), or an **admin** (e.g., a system administrator performing configuration tasks).

2. Object: An object refers to a **resource** or **data** that is being accessed, modified, or interacted with by the subject. Objects can be files, databases, network resources, or even hardware components, depending on the system.

- **Example**: In a file system, an object would be a **file** or **directory** (e.g., a Word document). In a database, an object could be a **record** or **table**.

3. Access Rights (or Permissions): Access rights (or permissions) define **what actions a subject is allowed to perform** on an object. These actions are

typically granted by the system administrator or via a policy that is based on the subject's role, identity, or other attributes.

- **Example**: A user might have **read**, **write**, or **execute** access rights on a file.
- **Common Types of Access Rights**:
  - **Read (R)**: The ability to view the contents of an object (e.g., opening and reading a document).
  - **Write (W)**: The ability to modify or update the contents of an object (e.g., editing a file).
  - **Execute (X)**: The ability to run or execute a program or script (e.g., running an application or script).
  - **Delete (D)**: The ability to remove or delete an object (e.g., deleting a file).
  - **Append (A)**: The ability to add data to an object without modifying the existing content (e.g., appending logs to a file).
  - **Create (C)**: The ability to create new objects or resources (e.g., creating a new document or directory).

Interaction between Subject, Object, and Access Rights

In an access control system, the subject attempts to perform an action (such as read or write) on an object. The system evaluates whether the subject has the appropriate **access rights** to perform that action. This evaluation is based on access control models like **RBAC (Role-Based Access Control)**, **DAC (Discretionary Access Control)**, or **MAC (Mandatory Access Control)**.

These elements—subject, object, and access rights—are central to understanding how access control systems manage and enforce policies for secure interactions between users and resources. Access control decisions depend on these concepts to ensure only authorized actions are allowed.

Role Base Access Control

Role-Based Access Control is one of the most commonly used access control models that assign permissions to roles, rather than to individual users. Users are then assigned to specific roles, which determine what access they have to resources. This model is widely used in organizations because it simplifies the management of permissions and helps ensure that users only have access to the resources they need to perform their jobs.

Key Concepts of Role Base Access Control

Roles:

- A **role** is a collection of permissions that defines the actions a user can perform within a system. Roles are typically based on job functions or responsibilities within an organization (e.g., Admin, Manager, Employee).
- **Role Hierarchy**: Roles can be hierarchical, meaning that higher-level roles inherit the permissions of lower-level roles. For example, a "Manager" role might have all the permissions of the "Employee" role plus additional management privileges.
- **Users**: A **user** is an individual or entity (e.g., a process or system) that requests access to resources. Users are assigned one or more roles, and the permissions granted to those roles determine the user's access level.
- **Permissions**: Permission is an action or set of actions that can be performed on a specific resource (e.g., reading, writing, or deleting a file). In RBAC, permissions are associated with roles, not directly with users.
- **Sessions**: A **session** is a mapping between a user and the roles they are currently assigned during a specific period of time. A user can have multiple session's active simultaneously, depending on the roles they are assigned.

Role Base Access Control simplifies the process of managing access control in complex systems, reduces the risk of errors, and provides a clear and scalable framework for controlling access to resources based on users' roles within an organization.

Important Question (Assignment 4)

Q.1 Explain access control principles.

Q.2 Define Access Control Context

Q.3 Explain policies for access control.

Q.4 Define Subject, object & access rights with its relationships.

Q.5 What is role-based access control? Explain in details